Add worker security settings to WorkerPool templates- PR #2428

Summary

The initial commit and test checked whether an application could start, save its state and resume after being paused or suspended. Those checks passed, but they did not test file ownership, permissions or non-root guest access.

New additional checks found failures in the first proposed capability-drop list. The revised patch keeps the permissions needed for these operations. Expanded testing passed 27 filesystem and lifecycle cases across gVisor on VMs, gVisor on metal and micro-VMs on metal. After integrating current upstream main and building fresh images, the permanent regression test also passed all four default-versus-restricted cases on gVisor VM and micro-VM metal. These checks verified file ownership and permission restore on both runtimes, plus non-root file access, setgid-file permissions and device-node creation on micro-VMs.

Process checks on the nodes showed that gVisor and virtiofsd still used separate namespaces, restricted filesystem roots and active seccomp filters.

Capability sets after testing

Workers currently run with a fixed capability set and Unconfined worker seccomp. This PR lets a pool remove the tested capabilities below and apply a worker seccomp profile and `noNewPrivileges`. These settings are opt-in.

Component	Existing capability set	Retained with the revised PR	Dropped
gVisor worker	13 capabilities	9: `NET_ADMIN`, `SYS_ADMIN`, `SETUID`, `SETGID`, `DAC_OVERRIDE`, `FOWNER`, `CHOWN`, `NET_RAW`, `SETFCAP`	`MKNOD`, `SETPCAP`, `SYS_CHROOT`, `SYS_PTRACE`
Micro-VM worker	15 capabilities	11: `NET_ADMIN`, `SYS_ADMIN`, `SETUID`, `SETGID`, `DAC_OVERRIDE`, `FOWNER`, `CHOWN`, `MKNOD`, `SETFCAP`, `FSETID`, `DAC_READ_SEARCH`	`NET_RAW`, `SETPCAP`, `SYS_CHROOT`, `SYS_PTRACE`
virtiofsd child	9 capabilities and its own seccomp filter	All 9 normal child capabilities	None

Both worker examples were tested with the amd64 Localhost seccomp profile and `noNewPrivileges: true`. virtiofsd explicitly uses `--sandbox=namespace` and `--seccomp=kill`; its child capabilities and file-handle mode are not rewritten.

Builds and setup

Build	Source	Purpose
First proposal	`de8cad90`, including the change in `5fb14a9e`	Identify which proposed capability drops break filesystem operations
Revised patch, fix1	Based on `de8cad90`; rebuilt controller and worker images	Retest file operations and sandbox isolation after the changes
Current integrated revision	Based on upstream `aba56bb7`; fresh API, controller, node-agent, worker and probe images	Run `TestWorkerSecurityFilesystem` with default and restricted workers on gVisor VM and micro-VM metal
Upstream worker comparison	`c427a6ae` workers and node-agent	Check filesystem behaviour without the PR changes

Runtime	Host	Coverage
gVisor	`m6i.xlarge` VM nodes	Application start, snapshots, pause/resume, suspend/resume, file operations and sandbox isolation
gVisor	`i4i.metal` node	Application start, snapshots, pause/resume, suspend/resume, file operations and sandbox isolation
Micro-VM and virtiofsd	`i4i.metal` node	Guest file operations, snapshots, pause/resume, suspend/resume and virtiofsd isolation
Micro-VM	`m6i.xlarge`	Not runnable here: the host has no `/dev/kvm`

Settings tested

The worker container dropped the container runtime's default capability set, then added the permissions selected by Substrate. Tests changed the list removed from that Substrate set.

Setting	Capability drops	Worker seccomp	`noNewPrivileges`
No capability drops	None	Unconfined	Omitted
Individual drop	One allowed capability at a time	Unconfined	Omitted
All allowed drops	Complete list for the runtime	Unconfined	Omitted
Profile only	None	PR amd64 Localhost profile	`true`
Combined restrictions	Complete list for the runtime	PR amd64 Localhost profile	`true`

The combined setting was repeated to check the result. There were nine settings cases for each runtime/host setup.

The initial application lifecycle checks also ran with `noNewPrivileges: true` and Unconfined worker seccomp.

CHANGES FROM THE FIRST PROPOSAL

Substrate defaults are the sets used before this PR. The proposal columns show the capabilities kept when all allowed drops are selected.

Component	Substrate defaults	First PR proposal	Revised PR	What changed
gVisor worker	13	7	9	Keep `CHOWN` and `FOWNER` for file ownership and permission restore
Micro-VM worker	15	4	11	Keep the permissions needed for file restore and guest filesystem operations
virtiofsd child	9	2	9	Preserve its normal permissions; remove the capability rewriting and file-handle override

Test sequence

For each filesystem case:

1. Create a new golden snapshot on the selected worker pool.
2. Resume an actor and run the filesystem checks.
3. Pause, resume and check again.
4. Suspend, resume and check again.
5. Read the worker and sandbox process state from the node.

Check	What was tested
File contents	Saved data could be read after pause/resume and suspend/resume
File ownership	UID/GID 1000 ownership could be set and restored
File permissions	Permission changes worked and were restored on non-root-owned files
Setgid files	The setgid bit could be set; its value was checked after restore
Device nodes	Guest device-node creation worked where supported
Hard links	Linked paths still shared the same file after restore
Symlinks	The link target and file contents were unchanged after restore
Setuid and sticky bits	Their values were checked after restore
User xattrs	Extended attributes could be set and restored where supported
Non-root access	UID 1000 could create and read a private file; UID 2000 was denied access where non-root execution worked

These checks ran on the container rootfs and a durable directory.

Failures found and fixes tested

Each failure below occurred when a proposed capability drop was applied, while the same operation worked without that drop.

Proposed drop	Failure found	Result after rebuilding the revised patch
Drop `CHOWN`	Both runtimes failed to restore non-root-owned files. Micro-VM guest `chown` also failed.	Drop rejected. Ownership and contents restored successfully.
Drop `FOWNER`	Both runtimes failed to restore modes on non-root-owned files. Micro-VM guest `chmod` also failed.	Drop rejected. Mode changes and restore passed.
Drop micro-VM `SETUID`	UID 1000 could not create a file on the container rootfs. It worked without the drop.	Drop rejected. Non-root creation/read passed; UID 2000 could not read the private file.
Drop micro-VM `FSETID`	Setting a setgid file silently produced mode `0755` instead of `2755`.	Drop rejected. The setgid bit was retained in the tested micro-VM cases.
Drop micro-VM `MKNOD`	Guest device-node creation was denied. It worked without the drop.	Drop rejected. Device-node creation passed.

`DAC_READ_SEARCH` and `SETFCAP` are also retained on micro-VM workers. The revised patch does not alter virtiofsd's normal child capability set to make a reduced worker start.

Sandbox and seccomp checks

Check	Outcome
gVisor sentry and gofers	Separate PID, mount, network and user namespaces, separate roots, inner seccomp filters and `no_new_privs` remained present
virtiofsd serving child	Separate PID, mount and network namespaces; its root matched the shared directory; its own seccomp filter and `no_new_privs` remained present
Revised virtiofsd permissions	Normal nine-capability child set retained. No `--modcaps` or file-handle override was passed.
Namespace mode without `SYS_CHROOT`	Started successfully
Forced chroot mode without `SYS_CHROOT`	Exited with code 1 and EPERM while entering the sandbox
Worker Localhost profile	Denied the targeted bpf, perf, io_uring, keyring, userfaultfd, file-handle and socket-family probes. Required namespace and mount calls remained available.

VALUE OF THE WORKER CAPABILITY DROPS

Capability dropped	Runtime	What is reduced
`SYS_PTRACE`	Both	Extra permission to inspect or alter other processes visible to the worker
`MKNOD`	gVisor	Permission to create ordinary device nodes; device-access rules still apply
`NET_RAW`	Micro-VM	Permission to open raw and packet sockets
`SETPCAP`	Both	A capability-management permission the tested worker paths do not need
`SYS_CHROOT`	Both	An unused chroot permission; the namespace sandbox still works

Both workers still need `SYS_ADMIN` for mounts and namespace setup. This PR adds restrictions to the workers that manage the existing gVisor and micro-VM sandboxes. It removes unused permissions, blocks selected system calls with seccomp, and prevents

privilege gains through program execution with `noNewPrivileges`.

Why this matters

The worker handles images, snapshots and sandbox setup. If it is compromised, restricting its permissions and system calls can limit the actions available to an attacker. The application still relies on gVisor or the micro-VM for its main isolation.

Protection	Security benefit	Limit
Capability drops	Remove particular process-control, device or raw-socket permissions from the worker	Other powerful permissions remain, especially `SYS_ADMIN`
Worker seccomp profile	Blocks unnecessary kernel interfaces, including bpf, perf, io_uring and keyring operations, even if the process has broad capabilities	Mount and namespace operations needed by Substrate remain available; the profile needs maintenance as runtimes change
`noNewPrivileges`	Stops execution of setuid or file-capability programs from granting additional privileges	Does not remove privileges the worker already holds

Risk versus reward

The gain is useful extra worker protection, but it is smaller than removing root or `SYS_ADMIN`. virtiofsd already has its own sandbox and seccomp filter; preserving those protections takes priority over reducing a capability count.

The main regression risks are guest operations needing a removed permission, a runtime update introducing a blocked syscall, and applying a Localhost profile that is missing on a node. Changing pool security settings also replaces worker pods, so rollout affects running applications.

The tests reduce those risks for the workloads and runtime builds exercised. They do not prove that every application or future runtime version will behave the same way. The ownership failures found during this work show why a successful start-and-resume test alone is insufficient.

DOES THIS MEET THE ORIGINAL DEPLOYMENT GOAL?

Only partly. Workers still run as root and retain `SYS_ADMIN` and `NET_ADMIN`. This PR does not reduce the node agent's host-path or kubelet access. An organisation that cannot allow those permissions would still need deployment exceptions or a separate design change.

ASSESSMENT

The strongest reason to pursue this work is the tested worker seccomp profile, supported by `noNewPrivileges` and conservative capability drops. The four-capability reductions alone are a more modest benefit.

A small, reviewed hardening change is worth considering. The wider per-pool configuration API has an additional maintenance cost and should be weighed against reviewed runtime-specific defaults. The PR should be presented as an incremental improvement, rather than a solution to Substrate's overall deployment-permissions requirements.